CC8130
Segurança na Informação

Modelagem de Ameaças

centro universitário FEI

Prof. Dr. Leonardo Anjoletto Ferreira

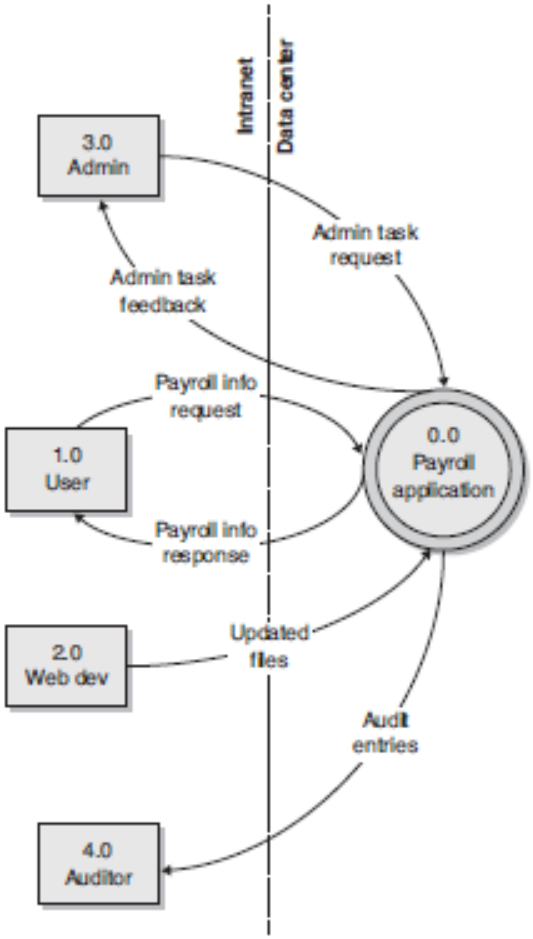
2º Semestre de 2024

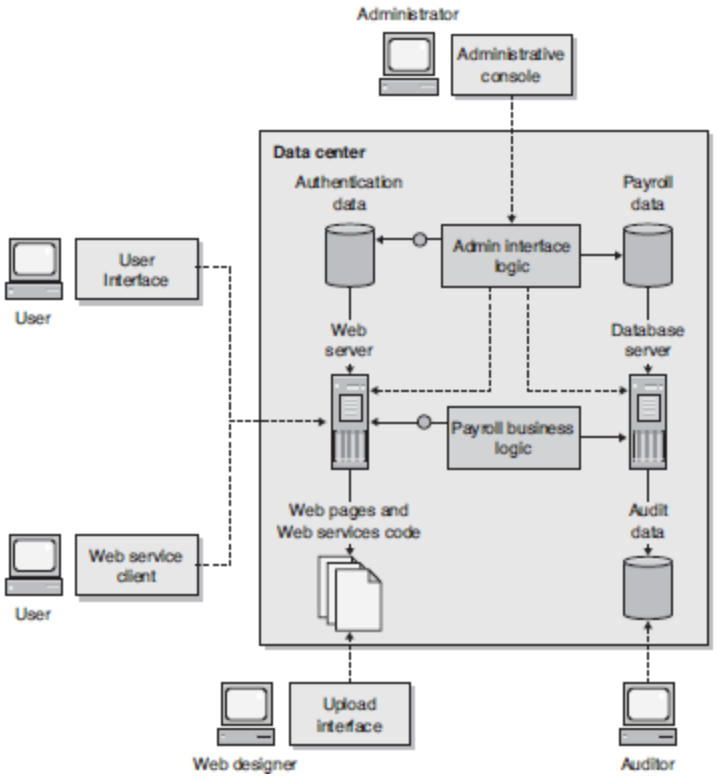
Não se pode construir um sistema seguro sem conhecer as suas ameaças!

Como modelar as ameaças?

- Spoofing of identity (*spoofing* de identidade)
- Tampering with data (Adulteração de dados)
- Repudiation (Repúdio)
- Information Disclosure (Revelação de Informações)
- Denial of Service (Negação de Serviço)
- Elevation of Privilege (Elevação de Privilégio)

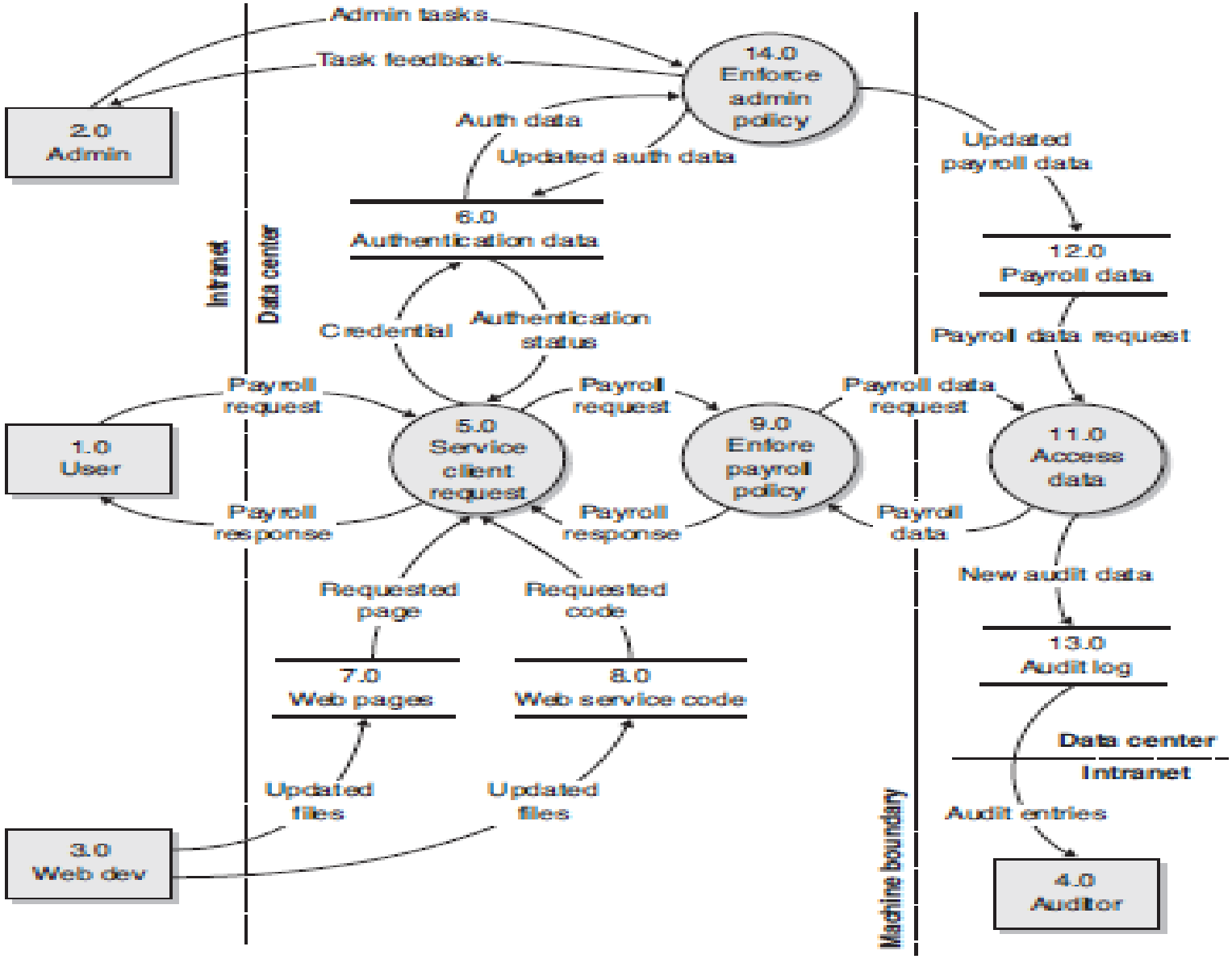
Uma aplicação “simples”....





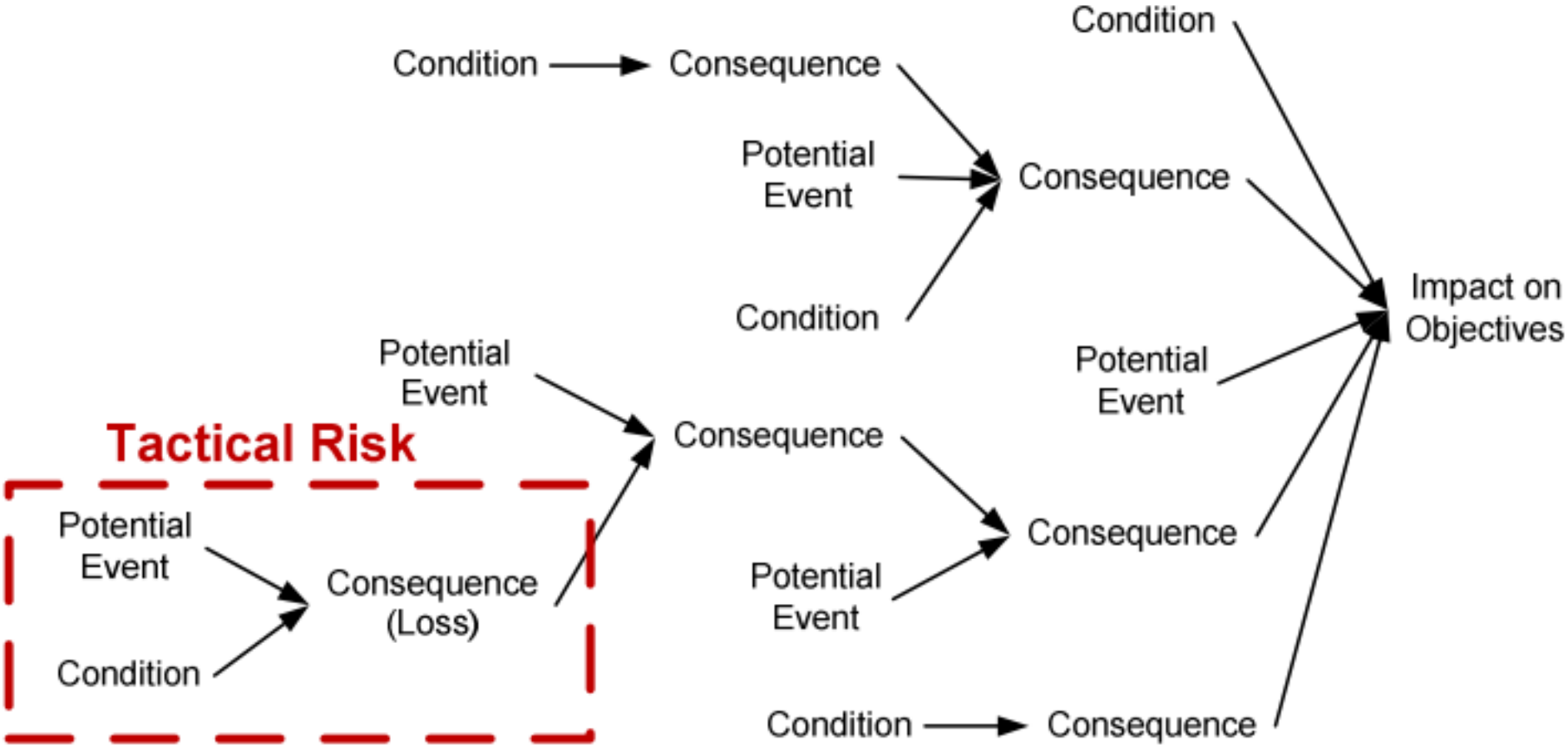
centro
universitário
FEI

...descendo um nível



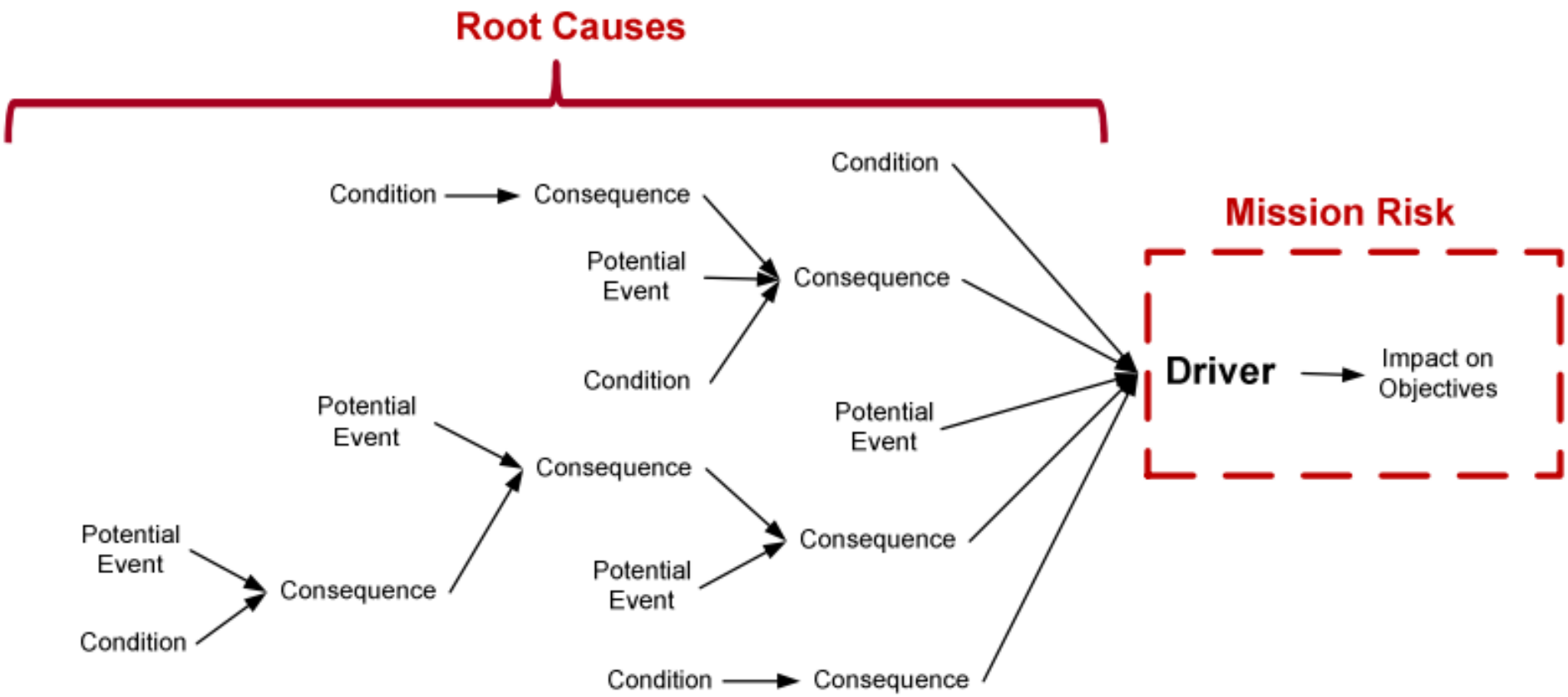
centro universitário FEI

Ameaças – como identificar I



centro universitário FEI

Ameaças – como identificar II

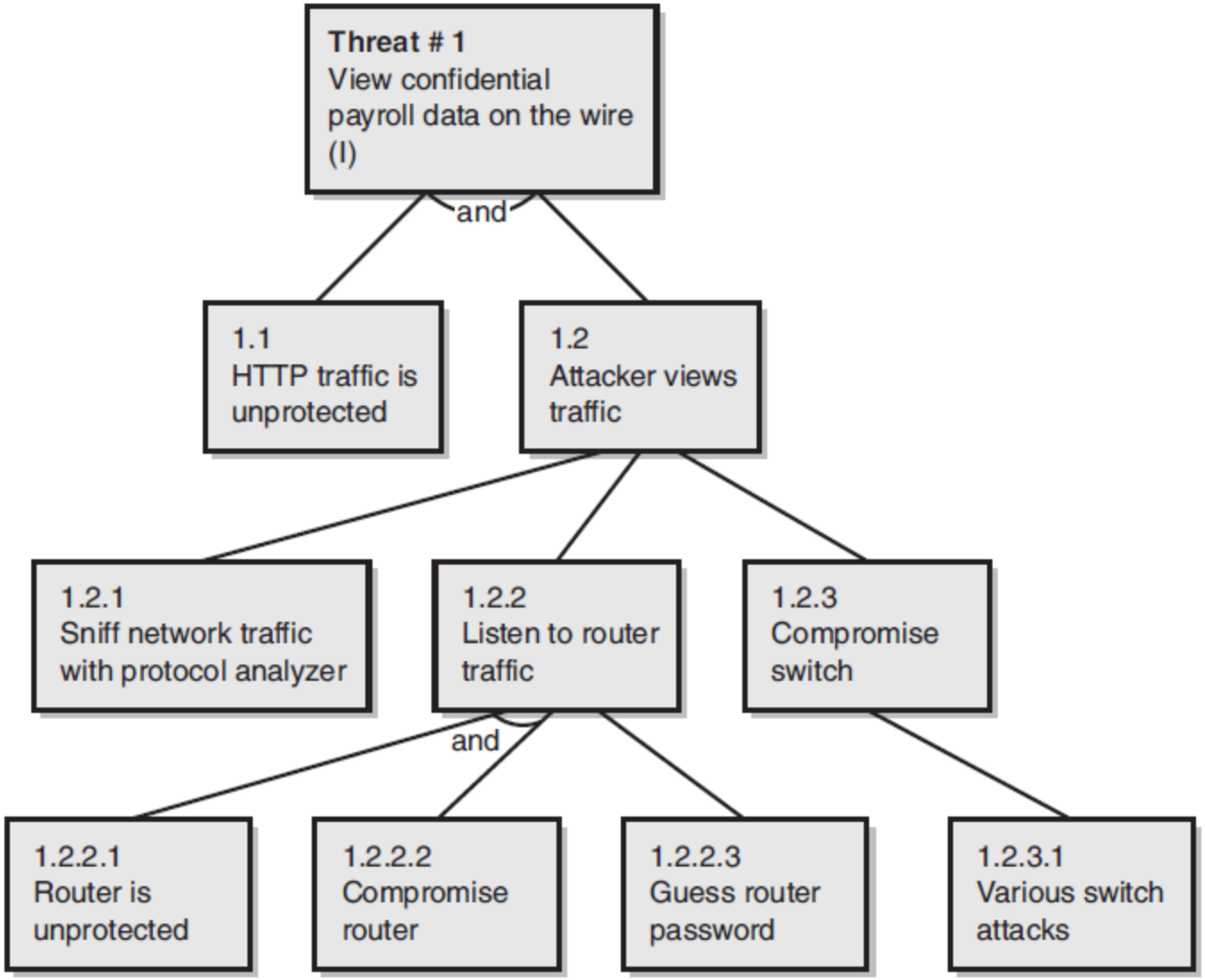


centro universitário FEI

Ameaças

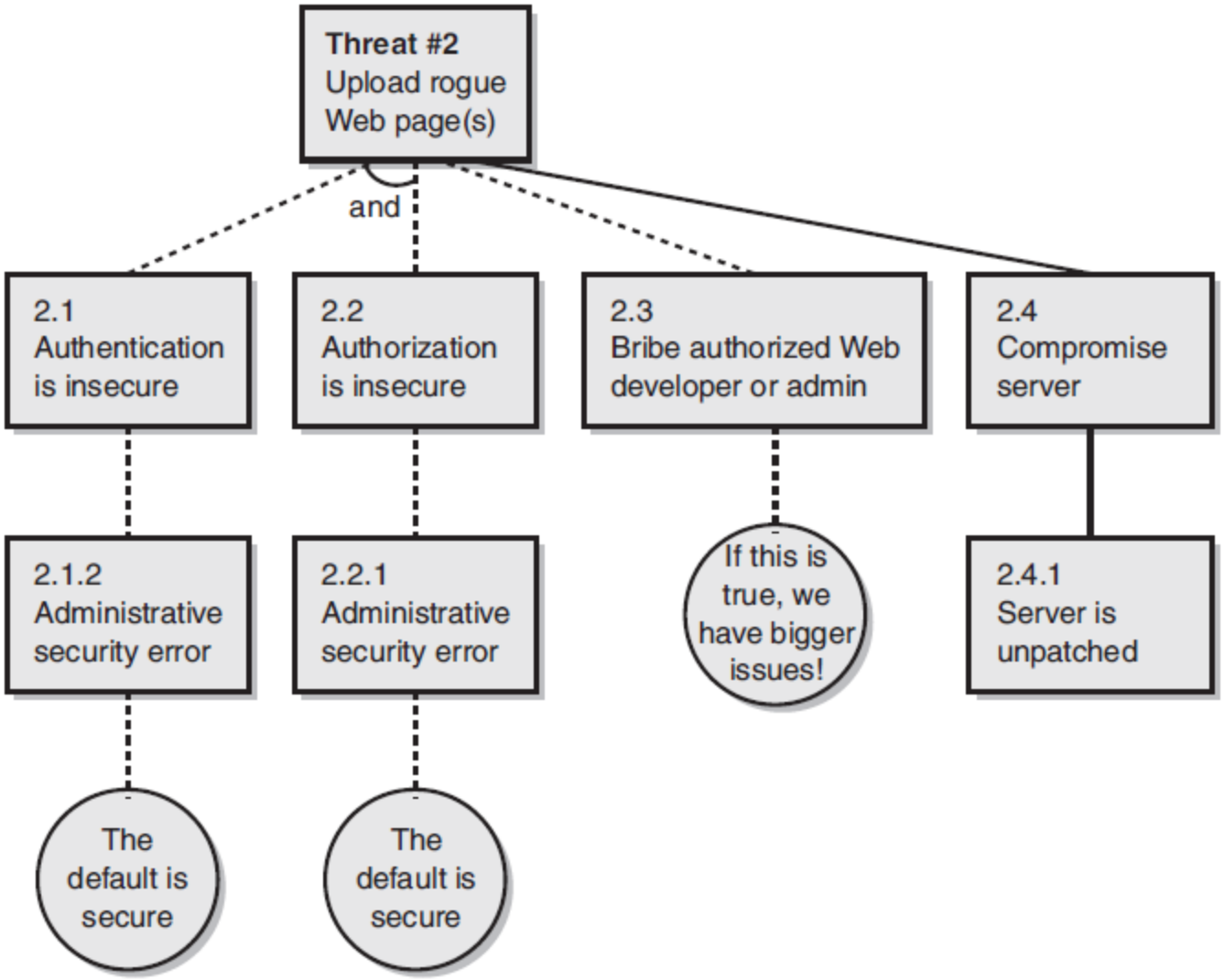
- Usuário mal intencionado visualiza dados confidenciais sobre a folha de pagamentos
- Invasor carrega páginas da WEB e códigos falsos
- Invasor nega serviço a um aplicativo
- Manipulação dos dados da folha de pagamentos
- Elevação dos privilégios, tirando vantagem do processo de solicitação de serviço de clientes
- Spoofing do computador que executa o processo de solicitação de processo de cliente

Árvores



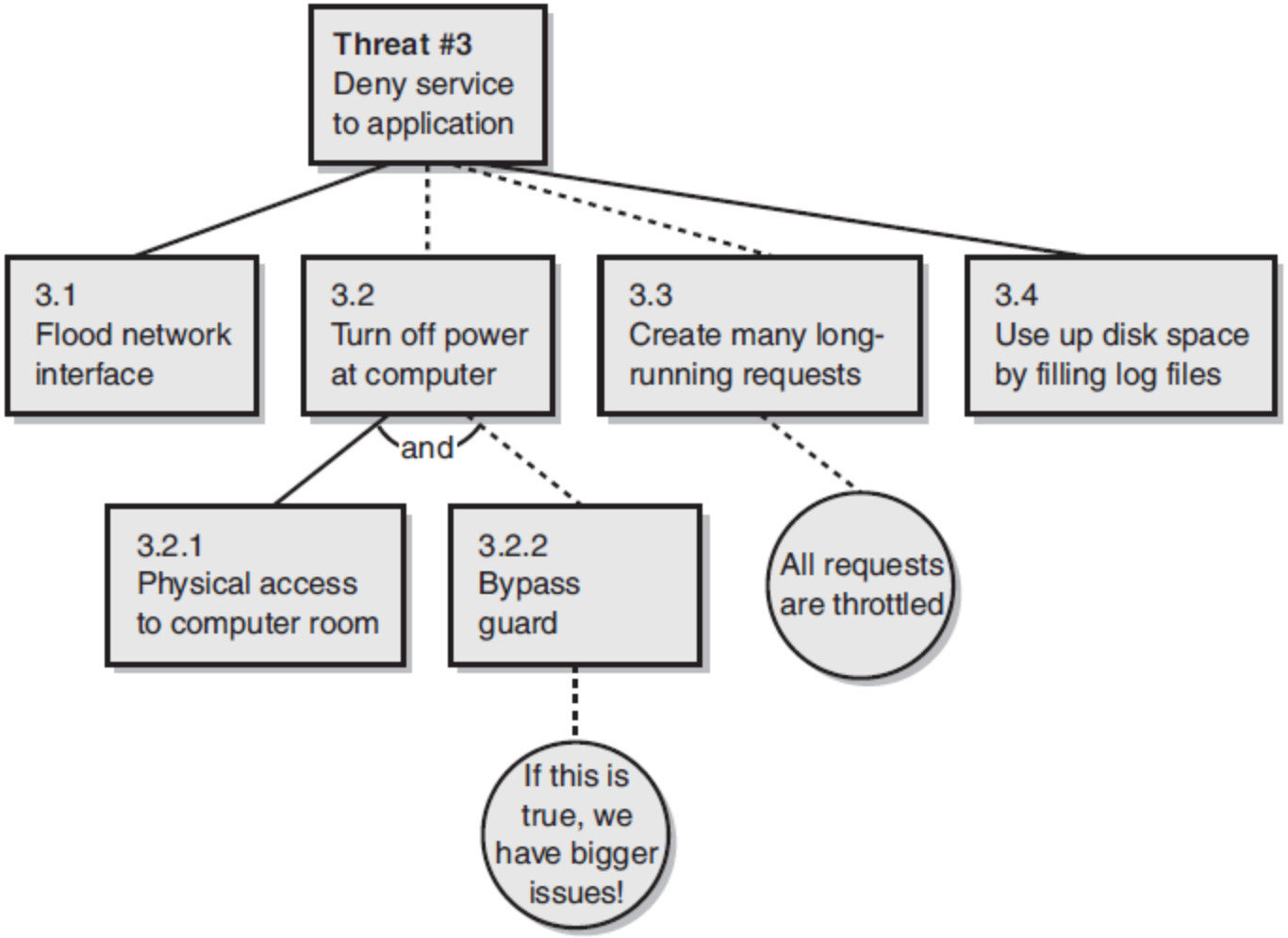
centro universitário FEI

Árvores



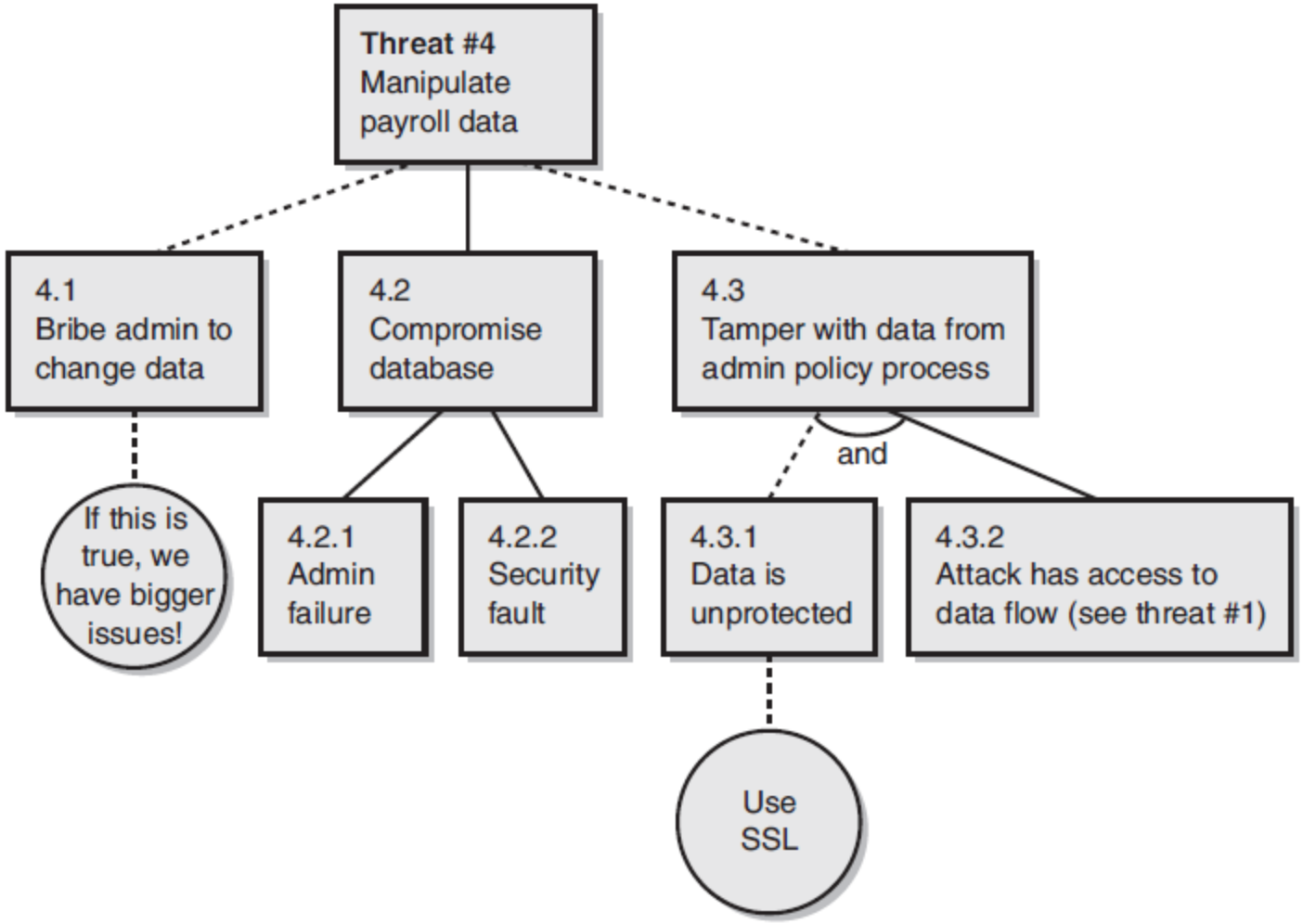
centro universitário FEI

Árvores



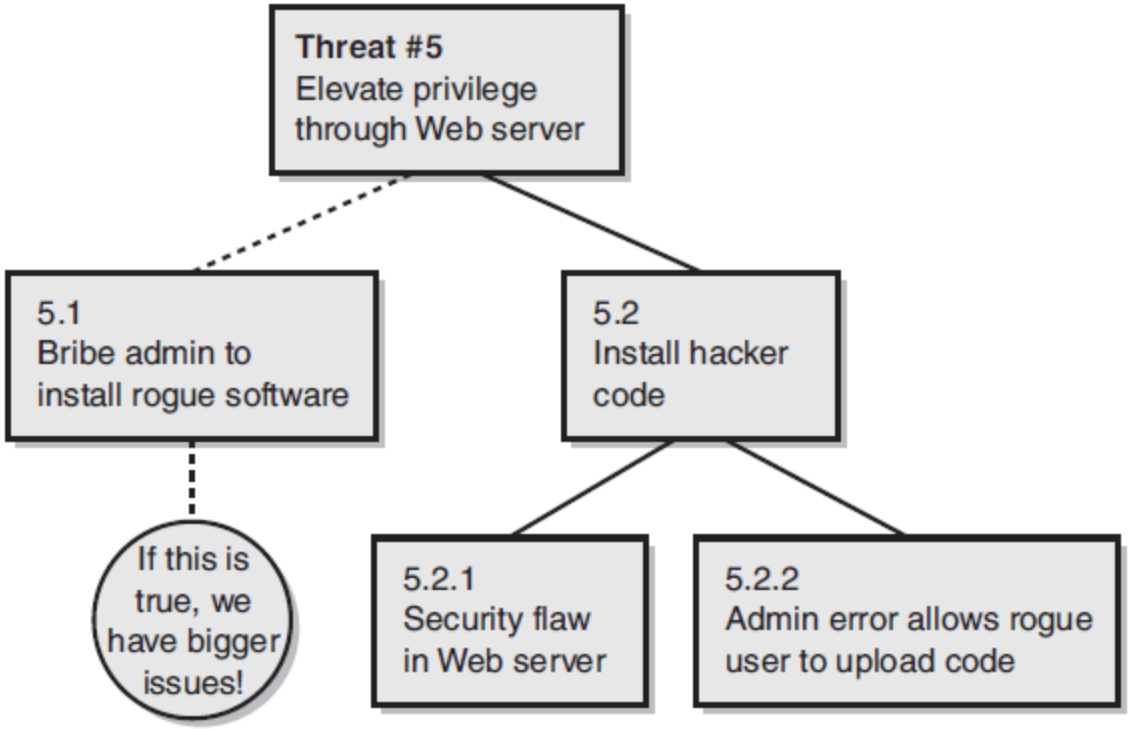
centro universitário FEI

Árvores

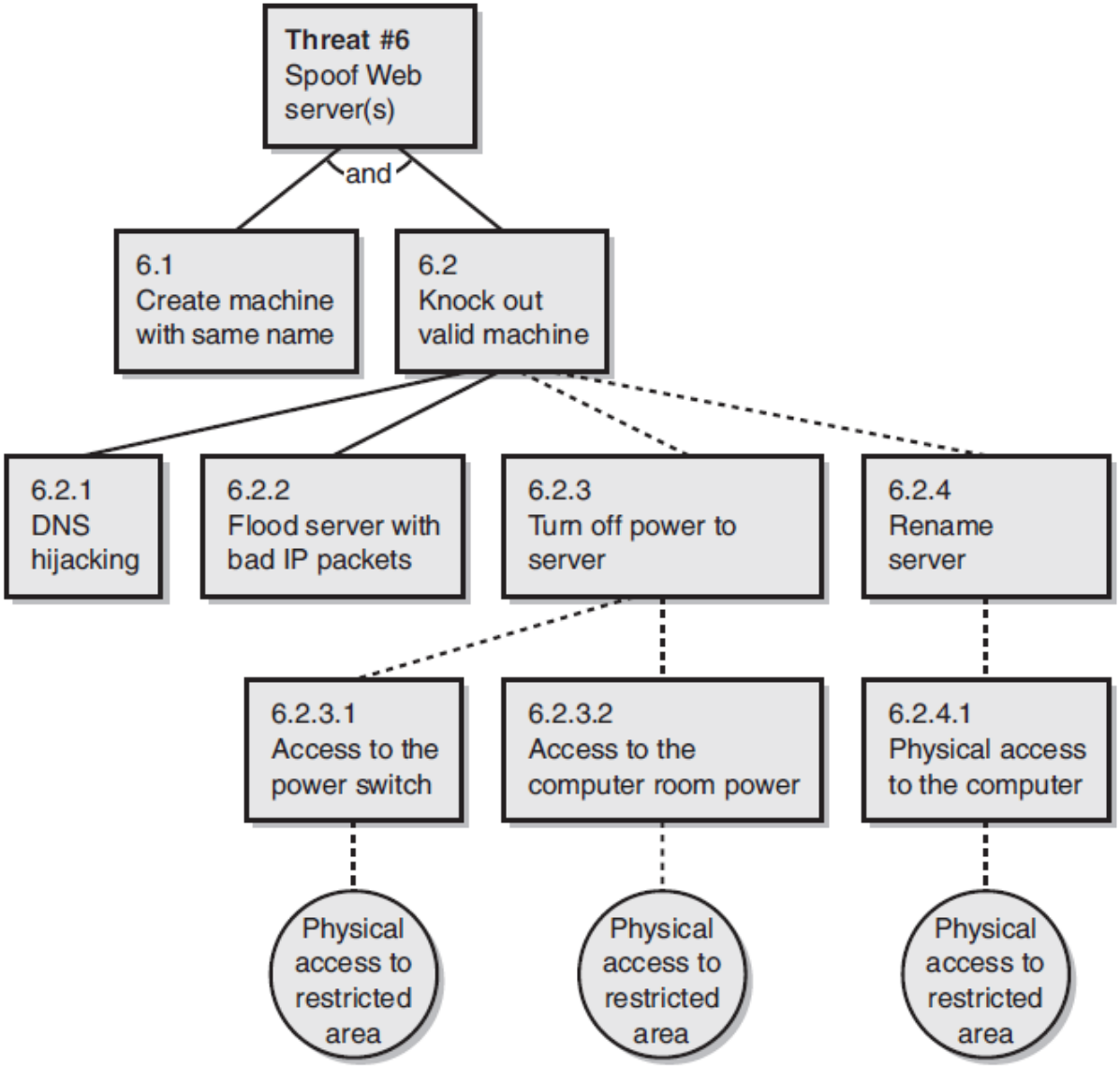


centro universitário FEI

Árvores


Threat #5
Elevate privilege through Web server
5.1
Bribe admin to install rogue software
5.2
Install hacker code
If this is true, we have bigger issues!
5.2.1
Security flaw in Web server
5.2.2
Admin error allows rogue user to upload code

Árvores



centro universitário FEI

Como medir as ameaça?

- Damage potential (*dano potencial*)
- Reproducibility (reproduzibilidade)
- Exploitability (explorabilidade)
- Affected user (usuários afetados)
- Discoverability (possibilidade de ser descoberta)

MEDINDO

Ameaça		D	R	E	A	D	RISCO
Usuário mal intencionado visualiza dados confidenciais sobre a folha de pagamentos							
Invasor carrega páginas da WEB e códigos falsos							
Invasor nega serviço a um aplicativo							
Manipulação dos dados da folha de pagamentos							
Elevação dos privilégios, tirando vantagem do processo de solicitação de serviço de clientes							
Spoofing do computador que executa o processo de solicitação de processo de cliente							

centro universitário FEI

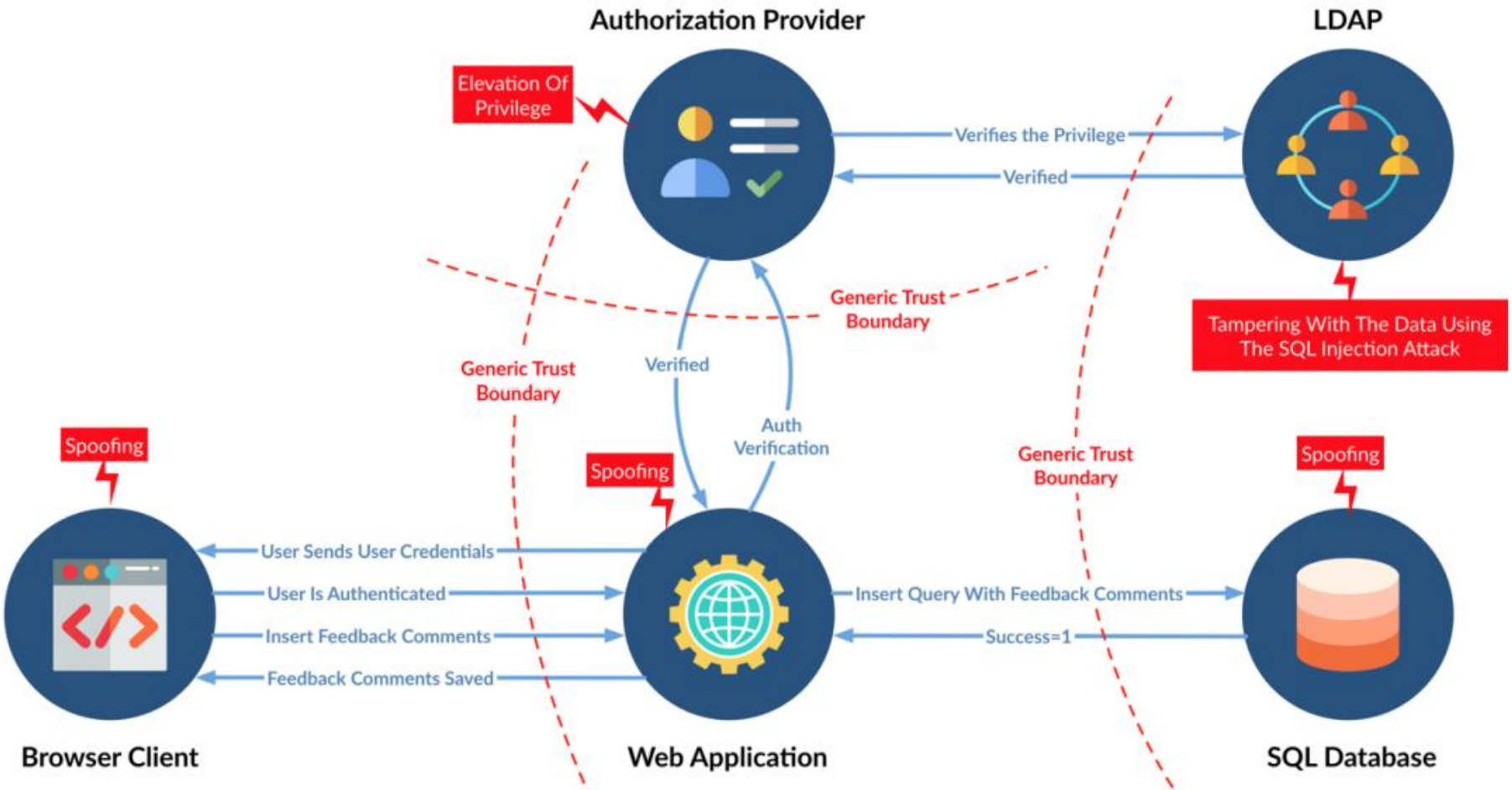
MEDINDO

Ameaça		D	R	E	A	D	RISCO
Usuário mal intencionado visualiza dados confidenciais sobre a folha de pagamentos	I	8	10	7	10	10	9,0
Invasor carrega páginas da WEB e códigos falsos	T	7	7	7	10	10	8,2
Invasor nega serviço a um aplicativo	D	6	6	7	9	10	7,6
Manipulação dos dados da folha de pagamentos	TI	10	5	5	10	10	8,0
Elevação dos privilégios, tirando vantagem do processo de solicitação de serviço de clientes	E	10	2	2	1	10	5,0
Spoofing do computador que executa o processo de solicitação de processo de cliente	S	10	2	2	8	10	6,4

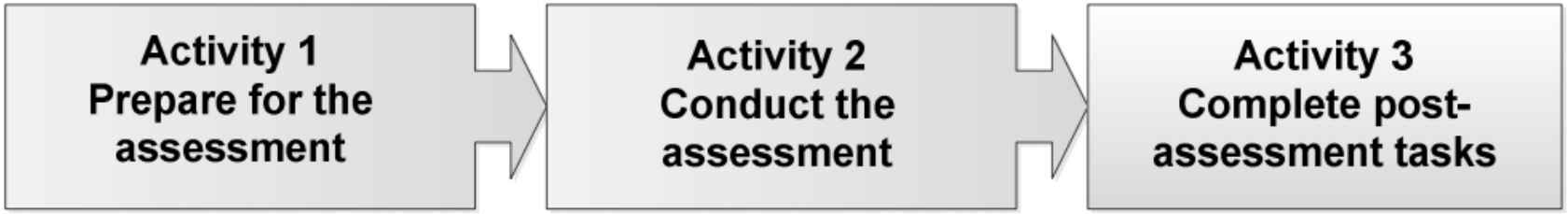
centro universitário FEI

Mais um exercício

https://safecode.org/wp-content/uploads/2017/05/SAFECode_TM_Whitepaper.pdf - *página 16*



Como fazer



Tasks
1.1 Form the assessment team
1.2 Develop stakeholder sponsorship
1.3 Set the scope of the assessment
1.4 Develop the assessment plan
1.5 Coordinate logistics
1.6 Tailor method and tools

Tasks
2.1 Identify mission and objective(s)
2.2 Identify drivers
2.3 Analyze drivers
2.4 Determine next steps

Tasks
3.1 Communicate results
3.2 Conduct assessment postmortem
3.3 Improve assessment process

centro universitário FEI

O que fazer:

- Nada
- Informar o usuário sobre a ameaça
- Remover o problema
- Corrigir o problema

ATIVIDADE

Qual o tema do seu projeto de formatura?

Faça um mapeamento das eventuais ameaças a este projeto

VAMOS DISCUTIR NA PRÓXIMA AULA!

Como modelar as ameaças?

- Spoofing of identity (*spoofing* de identidade)
- Tampering with data (Adulteração de dados)
- Repudiation (Repúdio)
- Information Disclosure (Revelação de Informações)
- Denial of Service (Negação de Serviço)
- Elevation of Privilege (Elevação de Privilégio)

Como medir as ameaça?

- Damage potential (*dano potencial*)
- Reproducibility (reproduzibilidade)
- Exploitability (explorabilidade)
- Affected user (usuários afetados)
- Discoverability (possibilidade de ser descoberta)

centro universitário FEI